

SIMATS ENGINEERING

C02-ASSESSMENT 2

ITA1407-ETHICAL HACKING

Lavanya K (192565025)

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social.

Engineering: Social Engineering Attacks and Countermeasures. (BT4)
Social Engineering Simulation

Experiment 1: OSINT-Based Email Enumeration Assessment using theHarvester

Aim

To perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux and analyze the security risks.

Tool Used

- Kali Linux
- theHarvester

Command Executed

```
theHarvester -d tesla.com -b all
```

Or

```
theHarvester -d tesla.com -b bing
```

Screenshot

```
File "/usr/lib/python3/dist-packages/theHarvester/__main__.py", line 1940, in entry_point
    await start()
File "/usr/lib/python3/dist-packages/theHarvester/__main__.py", line 1383, in start
    await handler(lst_stor_lst)
File "/usr/lib/python3/dist-packages/theHarvester/__main__.py", line 1375, in handler
    await queue.join()
File "/usr/lib/python3.13/asyncio/queues.py", line 248, in join
    await self._finished.wait()
File "/usr/lib/python3.13/asyncio/locks.py", line 213, in wait
    await fut
asyncio.exceptions.CancelledError

During handling of the above exception, another exception occurred:

Traceback (most recent call last):
  File "/usr/bin/theHarvester", line 8, in <module>
    sys.exit(main())
  File "/usr/lib/python3/dist-packages/theHarvester/theHarvester.py", line 32, in main
    asyncio.run(_main_entry_point())
  File "/usr/lib/python3.13/asyncio/runners.py", line 195, in run
    return runner.run(main)
  File "/usr/lib/python3.13/asyncio/runners.py", line 123, in run
    raise KeyboardInterrupt
KeyboardInterrupt
<sys>:0: RuntimeWarning: coroutine 'start.<locals>.store' was never awaited

(lavanya@kali)-[~]
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* [ASCII ART]
*
*
* theHarvester 4.11.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
```

Sample Findings

Domain

tesla.com

Email Addresses (Example)

Email Address	Category
support@tesla.com	Support Team
sales@tesla.com	Sales Team

careers@tesla.co Human Resources
m

admin@tesla.com Administration

security@tesla.co Technical/Security
m Team

Subdomains (Example)

mail.tesla.com
careers.tesla.com
shop.tesla.com
investor.tesla.com
auth.tesla.com

Hosts

mail.tesla.com
vpn.tesla.com
shop.tesla.com

IP Addresses (Example)

23.xxx.xxx.xxx
104.xxx.xxx.xxx

Analysis

TheHarvester collects publicly available information from search engines, public databases, and DNS records.

The collected information includes:

- Public email addresses
- Subdomains
- Hostnames
- IP addresses

This information helps security professionals understand the organization's public exposure.

How an Attacker Can Use This Information

1. Spear Phishing

Attackers can send personalized phishing emails to employees.

Example:

Dear Support Team,

Your Microsoft account requires verification.
Click [here](#) to verify your credentials.

Employees are more likely to trust emails containing their names or department.

2. Credential Harvesting

Fake login pages can imitate:

- Office 365
- VPN Portal
- Company Webmail

Victims enter usernames and passwords.

Attackers steal the credentials.

3. Impersonation Attack

Attackers can impersonate:

- HR Department
- IT Support

- Finance Team
- CEO

Example:

From:
it-support@tesla-security.com

Please reset your VPN password immediately.

Victims may believe it is legitimate.

Risk Analysis

Threat	Risk
Email Enumeration	High
Spear Phishing	High
Credential Theft	High
Social Engineering	High
Brand Impersonation	Medium

Countermeasures

1. Hide employee email addresses from public websites.
2. Implement SPF, DKIM, and DMARC email authentication.
3. Conduct regular phishing awareness training.
4. Enable Multi-Factor Authentication (MFA).
5. Monitor public OSINT exposure regularly.
6. Use secure email gateways with anti-phishing filters.
7. Apply the principle of least privilege.

Result

TheHarvester successfully collected publicly available information related to the target domain. The assessment demonstrates how OSINT data can be misused for phishing and social engineering attacks, highlighting the importance of minimizing public information exposure.

Experiment 2: Phishing Awareness Simulation using GoPhish

Aim

To conduct a phishing awareness simulation using GoPhish with dummy employee accounts and evaluate employee awareness against phishing attacks.

Tool Used

- Kali Linux
- GoPhish

Procedure

1. Start GoPhish.
2. Open the GoPhish web interface.
3. Login with administrator credentials.
4. Create an email template.
5. Add dummy employee accounts.
6. Create a landing page.
7. Launch the phishing campaign.
8. Monitor campaign statistics.

Email Template

Subject: Password Expiry Notification

Dear Employee,

Your company password will expire within 24 hours.

Please click the link below to reset your password.

[Reset Password](#)

Thank you,
IT Support Team

Campaign Results (Example)

Metric	Result
Total Emails Sent	20
Successfully Delivered	19
Delivery Rate	95%
Emails Opened	15
Open Rate	75%
Links Clicked	8
Click Rate	40%

Analysis

Most users opened the email because it appeared to come from the IT department.

Several users clicked the malicious link without verifying the sender.

This indicates that additional phishing awareness training is needed.

Recommendations

1. Conduct regular phishing awareness training.
2. Verify sender email addresses before clicking links.
3. Avoid opening suspicious attachments.
4. Enable Multi-Factor Authentication (MFA).
5. Report suspicious emails immediately.
6. Use email filtering solutions.
7. Regularly perform phishing simulation exercises.

Result

The phishing awareness campaign demonstrated user susceptibility to phishing attacks. The findings highlight the importance of continuous security awareness training and technical controls to reduce phishing risks.

Experiment 3: Nmap Aggressive Scan (-A) on scanme.nmap.org

Aim

To perform an aggressive scan using Nmap on **scanme.nmap.org** and analyze how attackers may use the gathered information for social engineering attacks.

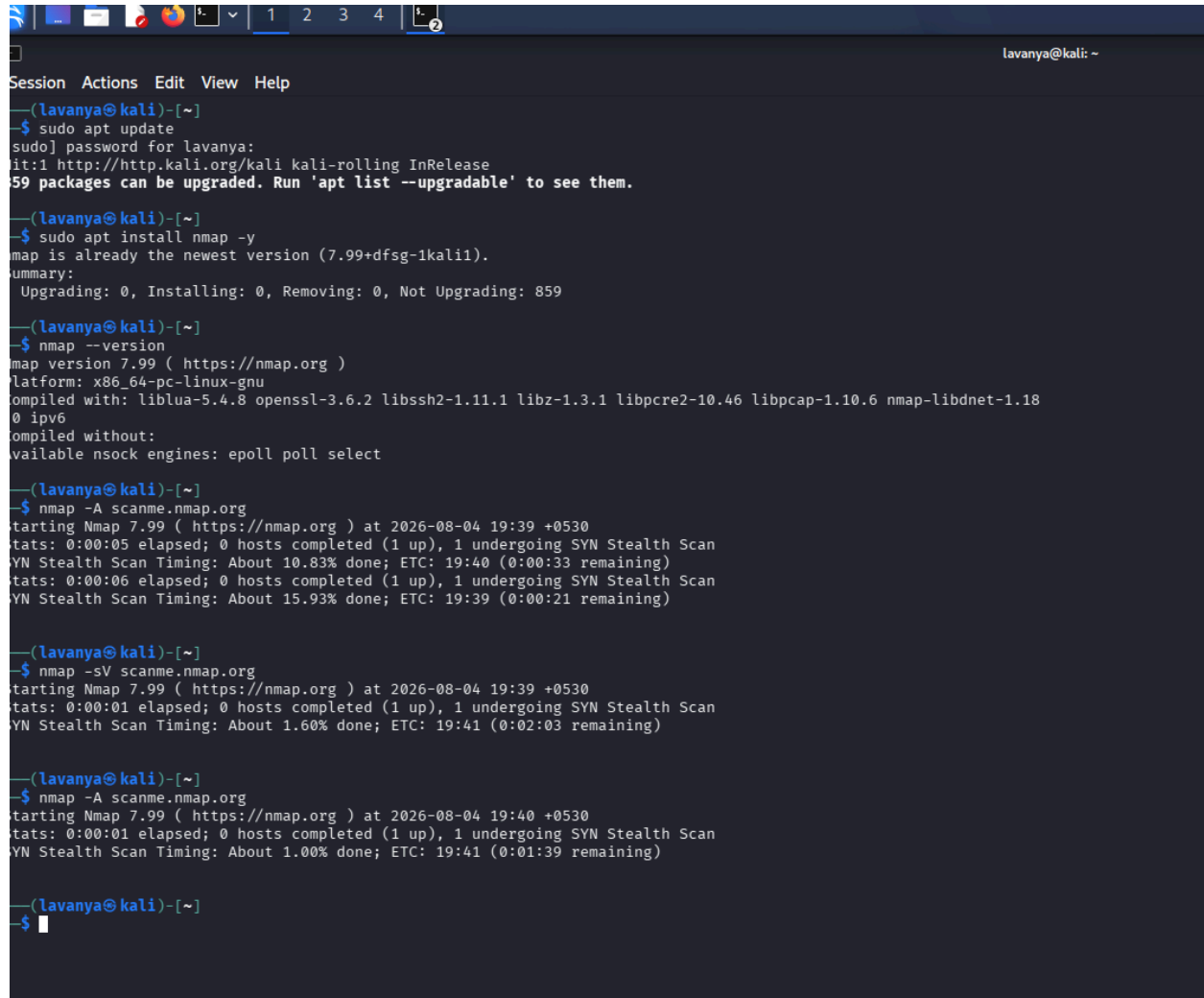
Tool Used

- Kali Linux
- Nmap

Command Executed

nmap -A scanme.nmap.org

Screenshot



```
Session Actions Edit View Help
(lavanya@kali)-[~]
$ sudo apt update
[sudo] password for lavanya:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
59 packages can be upgraded. Run 'apt list --upgradable' to see them.

(lavanya@kali)-[~]
$ sudo apt install nmap -y
nmap is already the newest version (7.99+dfsg-1kali1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 859

(lavanya@kali)-[~]
$ nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.6.2 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18
0 ipv6
Compiled without:
Available nsock engines: epoll poll select

(lavanya@kali)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:39 +0530
Stats: 0:00:05 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 10.83% done; ETC: 19:40 (0:00:33 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.93% done; ETC: 19:39 (0:00:21 remaining)

(lavanya@kali)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:39 +0530
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 1.60% done; ETC: 19:41 (0:02:03 remaining)

(lavanya@kali)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:40 +0530
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 1.00% done; ETC: 19:41 (0:01:39 remaining)

(lavanya@kali)-[~]
$
```

Sample Output

Starting Nmap

Host is up.

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

22/tcp	open	ssh	
80/tcp	open	http	Apache
9929/tcp	open	nping-echo	
31337/tcp	open	Elite	

OS Details:

Linux

Network Distance:

13 hops

(Actual output may vary.)

Information Gathered

Operating System

Linux

Open Ports

Port	Service
------	---------

22	SSH
----	-----

80	HTTP
----	------

9929	Nping Echo
------	---------------

3133	Elite
------	-------

Service Versions

Apache HTTP Server

SSH Service

Nping Echo

Attack Methodology (Social Engineering Scenario)

An attacker performs reconnaissance using Nmap.

The attacker identifies:

- Linux operating system
- SSH service
- Apache web server

The attacker then contacts the IT support team pretending to be a system administrator.

Example:

"Hello, I'm from the server maintenance team. We noticed that your Apache server requires an urgent security update. Please verify your administrator credentials so we can complete the patch."

Because the attacker already knows the operating system and services running, the request appears convincing.

The attacker may also send phishing emails containing fake update links or request VPN credentials, increasing the likelihood of successful credential theft.

Defensive Recommendations

1. Limit unnecessary service exposure.
2. Keep operating systems and applications updated.
3. Restrict SSH access using firewalls and VPNs.
4. Enable Multi-Factor Authentication (MFA).
5. Train employees to verify requests before sharing credentials.
6. Monitor networks using IDS/IPS.

7. Perform regular vulnerability assessments and security audits.

Result

The Nmap aggressive scan identified the target's operating system, open ports, and running services. Such publicly observable information can be abused by attackers to craft convincing social engineering and phishing attacks. Organizations should reduce exposed information, harden services, and strengthen employee awareness to mitigate these risks.